

VENDOR RISK MANAGEMENT POLICY

Global Trust Bank - Singapore

Field	Details
Document Title	Vendor Risk Management Policy
Document ID	GTB-POL-VRM-003
Version	3.2
Effective Date	February 1, 2026
Review Date	February 1, 2027
Owner	Chief Procurement Officer (CPO)
Approved By	Board Risk Committee
Classification	Restricted - Internal Use Only

1. EXECUTIVE SUMMARY

This Vendor Risk Management Policy establishes the comprehensive framework for identifying, assessing, monitoring, and mitigating risks associated with third-party vendors at Global Trust Bank in compliance with:

- Monetary Authority of Singapore (MAS) Guidelines on Technology Risk Management
- MAS Guidelines on Outsourcing
- ISO 37001:2016 Anti-Bribery Management Systems
- ISO 31000:2018 Risk Management
- SWIFT Customer Security Programme (CSP)
- Payment Card Industry Data Security Standard (PCI DSS) v4.0
- Singapore Personal Data Protection Act (PDPA)

1.1 Policy Objective

To ensure that vendor relationships support the Bank's strategic objectives while maintaining appropriate risk management controls throughout the vendor lifecycle from selection through termination.

2. GOVERNANCE STRUCTURE

2.1 Vendor Risk Oversight Committee (VROC)

Role	Responsibility
Chief Risk Officer (CRO)	Chairperson - Overall risk oversight
Chief Procurement Officer	Vice Chair - Vendor management
Chief Information Security Officer	Security assessment
Chief Technology Officer	Technology evaluation
Chief Compliance Officer	Regulatory compliance
Chief Legal Officer	Contract review
Head of Internal Audit	Audit oversight

Meeting Frequency: Monthly (minimum), Quorum: 5 members including CRO, Reporting: Board Risk Committee (quarterly)

3. VENDOR CLASSIFICATION AND RISK TIERING

3.1 Vendor Tier Definitions

Tier	Criticality	Examples	Risk Criteria
Tier 1 Critical	Mission critical to operations	Core banking, Payment systems, Primary data centers, SW, CDM infra, Difficult replacement (>6 months)	Core SW, SGD 10M annual, Difficult replacement (>6 months)
Tier 2 Important	Important but not critical	Secondary infrastructure, Non-core applications, IT, Office, SG, Services, Security, Replaceable in 3-6 months, SGD 1M annual	IT, Office, SG, Services, Security, Replaceable in 3-6 months, SGD 1M annual
Tier 3 Standard	Low operational impact	Office supplies, Travel services, Facilities, Training providers, SGD 1M annual, Easily replaceable (<3 months)	IT, Office, SG, Services, Security, Replaceable in 3-6 months, SGD 1M annual

3.2 Risk Scoring Model

Risk Factor	Weight	Scoring Criteria
Operational Criticality	30%	Business impact if vendor fails
Data Sensitivity	25%	Type and volume of data accessed
Financial Exposure	15%	Annual spend and liability exposure
Geopolitical Risk	10%	Vendor location and political stability
Cybersecurity Risk	10%	Security posture and history
Compliance Risk	5%	Regulatory requirements
Financial Stability	5%	Vendor financial health

Risk Rating Scale:

- Critical Risk: Score ≥ 85
- High Risk: Score 70-84
- Medium Risk: Score 50-69
- Low Risk: Score < 50

4. VENDOR LIFECYCLE MANAGEMENT

4.1 Four-Phase Vendor Lifecycle

Phase	Key Activities	Duration	Approval Required
Phase 1: Selection	Business need assessment, Market research, RFP process, Due diligence, Vendor evaluation	3-4 months	Business Owner, VROC (if Tier 1/2)
Phase 2: Onboarding	Contract negotiation, Vendor setup, Access provisioning, Implementation, Security testing	3-6 months	Legal, Security, Procurement
Phase 3: Ongoing Management	Performance monitoring, Risk monitoring, Compliance audits, Relationship management	Ongoing	Periodic VROC review
Phase 4: Renewal/Exit	Performance evaluation, Contract renewal, Termination planning, Data return, Access revocation	2-6 months	Business Owner, VROC

5. VENDOR DUE DILIGENCE REQUIREMENTS

5.1 Comprehensive Due Diligence Areas

- **Legal and Regulatory:** Corporate structure, litigation history, regulatory sanctions, licensing, anti-bribery policies, sanctions screening
- **Financial:** Audited financials (3 years), credit ratings, financial ratios, going concern, insurance coverage
- **Operational:** Business continuity plans, disaster recovery, incident response, change management, quality systems
- **Technical:** Technology architecture, scalability, integration capabilities, development methodology, support model
- **Security and Privacy:** Security program, certifications (ISO 27001, SOC 2), encryption, access controls, vulnerability management, data protection compliance
- **Geographic/Geopolitical:** Service locations, data center locations, political stability, data protection laws, government access laws

6. VENDOR PERFORMANCE MANAGEMENT

6.1 Service Level Agreements (SLAs)

Service Category	Typical SLA Metrics	Target
Application Hosting	Uptime %, Response time, Transaction success rate	99.9%
Software Development	Defect rates, Delivery timeliness, Code quality	95%
Infrastructure	Availability %, MTBF, MTTR, Capacity utilization	99.95%
Support Services	First response time, Resolution time, Escalation rate	90%
Security Services	Threat detection rate, False positive rate, Response time	99%

6.2 Vendor Scorecard

Category	Weight	Rating Method
Service Delivery	35%	SLA achievement, quality metrics
Security & Compliance	25%	Assessment results, incidents, audit findings
Relationship Management	15%	Responsiveness, collaboration, escalations
Financial Performance	15%	Cost management, invoicing accuracy
Innovation & Value	10%	Improvements suggested, business value delivered

7. CONCENTRATION RISK MANAGEMENT

7.1 Concentration Limits

- Single Vendor Limit: No single vendor may exceed 20% of total IT spend
- Service Category: Minimum 2 vendors for critical service categories
- Geographic Diversity: Maximum 40% vendors in single country (except Singapore)
- Parent Company Exposure: Limits apply at parent company level for subsidiaries
- Critical Services: No sole-sourcing without VROC approval

7.2 Monitoring and Reporting

Concentration metrics are monitored quarterly with alerts triggered at 80% of limits. Annual concentration reviews assess diversification strategies.

8. VENDOR SECURITY REQUIREMENTS

8.1 Minimum Security Requirements (All Vendors)

- Written information security policy
- Regular security training for staff
- Access control and authentication
- Encryption (data at rest and in transit)
- Vulnerability management program
- Patch management
- Anti-malware protection
- Network security controls
- Logging and monitoring

8.2 Additional Requirements (Critical/High-Risk Vendors)

- ISO 27001 certification or equivalent
- SOC 2 Type II report (annual)
- Penetration testing (annual minimum)
- Security incident response plan
- 24-hour breach notification
- SIEM implementation
- DDoS protection
- Web application firewall
- Privileged access management
- Security operations center (SOC)

9. KEY PERFORMANCE INDICATORS

KPI	Target	Threshold	Frequency
% Critical vendors with current risk assessment	100%	<95%	Monthly
% Vendors meeting SLA targets	>95%	<90%	Monthly
Average vendor risk score (critical)	<50	>70	Quarterly
Vendor-caused incidents (P1/P2)	<3/quarter	>5	Monthly
% Vendors with current certifications	100%	<95%	Quarterly
Concentration risk (single vendor %)	<15%	>20%	Monthly
% Overdue vendor reviews	0%	>5%	Monthly
Vendor audit findings (high/critical)	<5/year	>10	Quarterly

DOCUMENT HISTORY

Version	Date	Author	Changes Summary
1.0	Jan 10, 2020	Procurement	Initial policy creation
2.0	Jun 15, 2022	Vendor Risk Mgmt	Major revision: risk tiering, enhanced DD, MAS requirements
3.0	Mar 20, 2024	Vendor Risk Mgmt	New governance, enhanced security, added ESG
3.1	Oct 5, 2025	Vendor Risk Mgmt	Concentration limits, cloud requirements, KRI targets
3.2	Feb 1, 2026	Vendor Risk Mgmt	AI/ML vendors, quantum readiness, geopolitical risk

APPROVAL SIGNATURES

Role	Name	Date
Chief Executive Officer	Robert Chen	February 1, 2026
Chief Risk Officer	Jennifer Tan	February 1, 2026
Chief Procurement Officer	Michael Wong	February 1, 2026
Chief Information Security Officer	Sarah Ng	February 1, 2026
Board Risk Committee Chair	Dr. William Koh	February 1, 2026